IA05: API Contract - Place Order

Video: {{VIDEO_URL - add after recording}} · **Diagram:** See attached

IA05_sequence (exported from draw.io)

Identity, purpose and role

Field	Value
Caller	Customer's browser (or future mobile app)
Provider	PHP server, checkout.php
Goal	Accept a valid checkout submission and create one order, one set of order items and one payment atomically
Method	POST
Endpoint	/checkout.php
Auth	PHP session cookie; customer must be logged in
Content-Type	application/x-www-form-urlencoded

Request fields

Fi ld Field	T Type	R i d Required	M i Meaning
csrf_token	string	Yes	CSRF token from $_SESSION['csrf_token']
checkout_token	string	Yes	One-time token preventing duplicate orders
fulfilment	enum: pickup, delivery	Yes	Defaults to pickup if missing or invalid
delivery_address	string	If delivery	Customer's delivery address
scheduled_for	string Y-m-d\TH:i	No	Future time for scheduled order; absent = ASAP
payment_method	enum: cash, mobile_money, card	Yes	Defaults to cash if invalid

Item names, quantities and prices are NOT sent by the browser. The server reads them from $_SESSION['cart'] and re-reads prices from menu_items (TC-14).

Validation rules

1. Login required - otherwise 302 → login.php
2. Non-empty cart after DB avlability re-check - otherwise 302 → cart.php
3. CSRF token must match (hash_equals) - otherwise 419
4. Checkout token must match - otherwise re-render with expiry message
5. Delivery address required when fulfilment=delivery
6. Scheduled time must be a valid future datetime if provided
7. Prices and avlability re-read from DB - browser values ignored
8. Quantity capped 1–20; notes capped 250 chars

Success response

Status: 302 · **Location:** my_orders.php?placed=<orderId>

Side effects: row in orders , rows in order_items , row in payments (all committed); $_SESSION['cart'] cleared; $_SESSION['checkout_token'] rotated.

Error model

Trigger	Outcome	User message
Missing/bad CSRF token	419	"Your form session expired. Refresh and try agn."
Delivery, empty address	200 re-render	"Enter a delivery address."
Schedule in past or malformed	200 re-render	"Enter a valid schedule date and time." / "Scheduled time cannot be in the
All items unavlable	302 → cart.php	(cart page informs customer)
DB error	200 re-render	"We could not save the order. Please try agn."

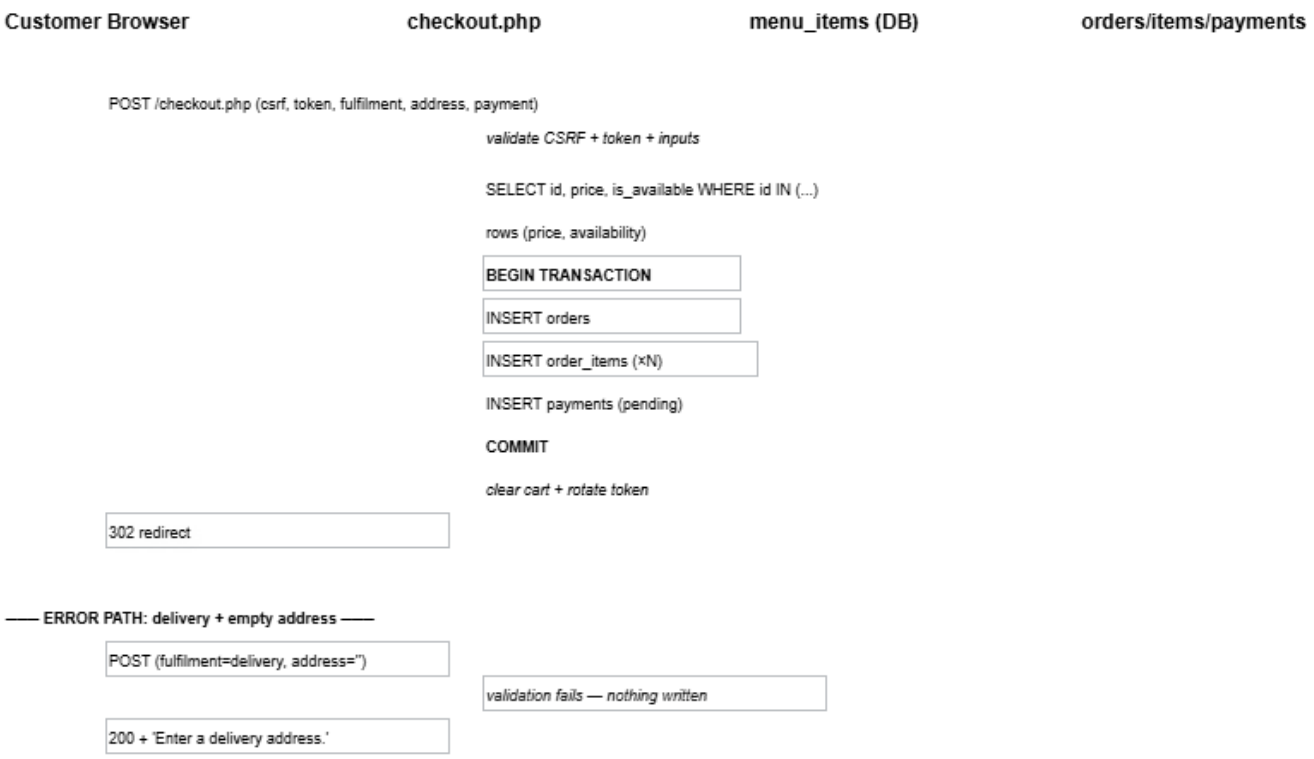
Duplicate (stale token)	200 re-render	"This checkout form was already submitted or expired."
Not logged in	302 → login.php	(login page)

Retry safety

- After validation error: safe - nothing written.
- After DB error: safe - cart and token preserved.
- After success: blocked - token rotated.
- Network drop after 302 sent: order exists; my_orders.php shows it.

Contract test plan

#	**Input**	**Expected**	**Status**
T1	Valid pickup, cash	302, total GH₵78.00, status received	Existing: TC-15
T2	Delivery, empty address	200, "Enter a delivery address."	Existing: TC-16
T3	Duplicate submit (stale token)	200, 1 order in DB only	Existing: TC-18
T4	Price tampered in session	DB price used, not tampered value	Existing: TC-14
T5	DB fls mid-insert	200, "could not save", 0 orders	Planned
T6	Schedule in past	200, schedule error message	Planned


Customer Browser
checkout.php
menu_items (DB)
orders/items/payments
POST /checkout.php (csrf, token, fulfilment, address, payment)
validate CSRF + token + inputs
SELECT id, price, is_available WHERE id IN (...)
rows (price, availability)
BEGIN TRANSACTION
INSERT orders
INSERT order_items (×N)
INSERT payments (pending)
COMMIT
clear cart + rotate token
302 redirect
—— ERROR PATH: delivery + empty address ——
POST (fulfilment=delivery, address='')
validation fails — nothing written
200 + 'Enter a delivery address.'